

Management should consider the needs of internal and external stakeholders¹⁰ when making decisions regarding IT development, acquisition, and maintenance activities. Effective communication helps stakeholders carry out their roles and responsibilities and supports entity-wide alignment of these IT activities with an entity's strategic plans. Effective communication also helps stakeholders appropriately identify, assess, and mitigate risks and their potential impacts. Additionally, when contemplating IT projects and activities, management should consider business strategies and objectives, resilience needs, information security requirements, legal and regulatory requirements, and allocation of resources (e.g., personnel, budget, and time).

II.A Policies, Standards, and Procedures

Effective management develops and implements comprehensive, entity-wide IT policies, standards, and procedures covering the development, acquisition, and maintenance life cycle. Large or complex entities may have multiple policies for different business line functions and their underlying systems and components. The board and designated owners or committees should regularly review and approve IT policies. Policies should clearly delineate development, acquisition, and maintenance responsibilities and provide for communication to all personnel, stakeholders, and appropriate third parties. Standards, on the other hand, may be used to define the processes and rules to support IT policies. For example, software developers often use coding standards in their work. Procedures are often developed to provide instructions to perform a function or task to align with IT policies and standards and may be adjusted to meet changes in the entity's IT environment. Periodic adjustments to standards and procedures may be needed to continue to align with the board-defined risk appetite, threat environment, and risks to the entity and its customers. Management should review and approve deviations from policies, standards, and procedures related to development, acquisition, and maintenance. For example, if the entity's policy prohibits the use of open-source software, management should approve any exceptions when developers use open-source software.

II.B Roles and Responsibilities

The board should oversee and management should implement the entity's development, acquisition, and maintenance activities by identifying and assigning appropriate roles and responsibilities. Assigning roles and responsibilities helps management to assign decision-making authority to an appropriate individual or team. Designated roles and responsibilities allow management and stakeholders to identify relevant lines of communication. Additionally, management may specify qualifications, competence, skills, and expertise needed in various roles. Examples of common roles related to development, acquisition, and maintenance activities are described in the following sections of this booklet. In smaller or less complex entities, formal roles may not be established; however, management should identify and assign the responsibilities described in these sections. As appropriate for the needs of the entity, it is important to consider training needs to support development, acquisition, and maintenance

¹⁰ For purposes of this booklet, stakeholders may include management or designated individuals from all departments affected by the proposed project (e.g., information technology [IT], legal, compliance, independent risk management, business process owners, and audit), and board members. At times, stakeholders can also include external entities (e.g., clients, consumers, customers, or customers of financial institution clients of a third-party service provider).

responsibilities. For more information about IT roles and responsibilities in general, refer to the *FFIEC IT Handbook's* "[Management](#)" booklet.

II.B.1 Board, Senior Management, and Other Common Roles

Primary roles and responsibilities for the board and senior management for development, acquisition, and maintenance activities should include the following:

- **Board:** The board, or board-designated committee,¹¹ typically confirms that IT-related development, acquisition, and maintenance activities align with entity strategic objectives and the board's risk appetite. The audit committee of the board is involved with reviewing and validating the entity's audit-related activities, including development, acquisition, and maintenance.¹² Additionally, the board generally approves
 - Significant IT investments.
 - Policies and standards.
 - Significant IT projects that may affect the entity's strategic direction.¹³

Board members should have appropriate knowledge of risks to provide a credible challenge¹⁴ to management responsible for development, acquisition, and maintenance functions.

- **Senior management:** Senior management approves and champions development, acquisition, and maintenance projects within its authority, ensures that project execution is in alignment with entity objectives and risk appetite, and ensures that adequate resources, including qualified staff, are available to complete IT projects.
- **Chief information officer (CIO):** The CIO leads day-to-day IT system and component development, acquisition, and maintenance in accordance with the entity's policies and business strategy. Prudent practices include the CIO consulting with the entity's risk management function and legal counsel to ensure that development, acquisition, and maintenance decisions are consistent with sound risk management principles and applicable laws and regulations. Additionally, the CIO facilitates the integration of any new projects, systems, and components into the entity's operations to ensure that they align with strategic objectives and IT strategies. The CIO helps determine the feasibility of proposed projects or changes.

¹¹ For purposes of this booklet, when the role of the board is mentioned, it can be inferred that this role may be fulfilled by a board-designated committee, as appropriate, unless otherwise stated. An example of a board-designated committee is the architectural review board, which is common in larger or more complex entities.

¹² For more on the general role of audit and its responsibilities, refer to the *FFIEC IT Handbook's* "[Audit](#)" booklet.

¹³ Generally, the board approves critical operations and core business functions. For more information, refer to the following guidance: FDIC Financial Institution Letter (FIL) 103-2020, "[The FDIC Publishes Sound Practices to Strengthen Operational Resilience](#)"; FRB Supervision and Regulation (SR) Letter 20-24, "[Interagency Paper on Sound Practices to Strengthen Operational Resilience](#)"; and OCC Bulletin 2020-94, "[Operational Risk: Sound Practices to Strengthen Operational Risk](#)."

¹⁴ A credible challenge involves being actively engaged, asking thoughtful questions, and exercising independent judgment.

- **Chief information security officer (CISO):** The CISO typically develops enterprise-wide cybersecurity and information security policies and standards, including procedures promoting secure development, acquisition, and maintenance practices, and provides input for the consideration and inclusion of security and resilience in IT projects. The CISO is responsible for validating that security and resilience are maintained throughout the life of a project, system, or component.
- **IT steering committee:** An IT steering committee typically reviews and approves major development, acquisition, and maintenance proposals. Additionally, the committee provides a credible challenge to IT project managers and management responsible for development, acquisition, and maintenance activities. The credible challenge allows management to verify that projects adhere to entity policies, standards, and procedures; that project managers identify and appropriately mitigate risks; and that project costs stay within the allocated budget. The IT steering committee is responsible for reporting to the board and overseeing any issues (e.g., project issues or failure to meet standards) or additional project needs (e.g., additional funds and resources) by translating technical concepts in a way that is clear and understandable to relevant stakeholders.

II.B.2 IT Project Management Roles

There are multiple IT project management roles that, when performed effectively, can play a significant part in a project's success. A project can be part of larger programs, which may include multiple related projects. Roles may overlap in smaller or less complex entities or projects, which is acceptable if mitigating controls are in place. Segregation of duties and dual controls or other compensating controls are important for development, acquisition, and maintenance projects. For example, segregation of duties helps ensure that one person cannot use projects to misappropriate entity funds; purchase substandard software, hardware, or components; or initiate inappropriate contracts. Additionally, a key concern is that seemingly small problems in IT projects can quickly escalate in scale. Dual control may be used to mitigate this risk because it allows for problems to be identified and addressed earlier since no single person or group can make final decisions without agreement from others. For example, during development, code review involves a second individual to review code before it is released to test environments. Segregation of duties and dual control help foster security and resilience. For more information, refer to the "[IT Project Management](#)" section of this booklet. Common IT project management roles and responsibilities include the following:

- **Sponsor:** A project's sponsor is the most senior role in the project or program, which may contain multiple projects. Depending on the project's size and complexity, there may be more than one sponsor. Responsibilities include obtaining stakeholder endorsement for the project based on its objectives and business case,¹⁵ providing resources, and appointing the project owner. The sponsor represents the project in discussions with senior management, provides both formal and informal support to project teams, and promotes the positive aspects of the changes resulting from the project. The sponsor works with senior stakeholders

¹⁵ A business case provides justification to undertake a project, and the business case identifies the benefit, costs, and provides a rationale for the preferred solution. For more information, refer to the Project Management Institute (PMI), "[Is This Really Worth the Effort? The Need for a Business Case.](#)"

to resolve strategic issues across projects in a program or among projects. Additionally, the sponsor approves milestones and confirms the project's successful delivery.

- **Project owners:** A project owner typically helps determine a project's vision and guides progress toward the objectives to meet that vision throughout the project life cycle. The project owner manages key project risks to maintain alignment between the entity's objectives and those of the project. Additionally, the project owner obtains resources from the sponsor, serves as the primary communication link with management and other stakeholders, and is responsible for the successful completion of the project.
- **Product owner:** A product owner represents the business line stakeholders (e.g., team, department, or customer) for the team that undertakes the project. The product owner ensures that the project team delivers the most value by helping to prioritize deliverables. The product owner is responsible for communicating project status with the business line stakeholders.
- **Project or program managers:** Project or program managers are responsible for working with the business change manager to plan and monitor the project or program tasks. Additionally, they verify that tasks align with the objectives throughout the project's or program's life cycle. They are responsible for defining success and providing oversight for the completion of tasks and successful delivery of the project's or program's objectives. Project or program managers tend to have practical project management experience rather than specific business line expertise. They monitor and manage resources to stay within timelines and budget, including coordinating between projects and managing project interdependencies. Additionally, project or program managers manage issues and direct corrective action when necessary. They monitor, report, and communicate a project's or program's status to management and other stakeholders. Lastly, project or program managers maintain all project documentation.
- **Business change manager:** A business change manager represents the business line for projects or programs in discussions with others. The role includes highlighting and focusing on benefits and risks for the business line and identifying the appropriate timing (for example, during periods of lower volumes) of implementation and releases. The business change manager plans and manages the integration of the changes in business line systems or processes, including identifying new business processes, to meet strategic objectives. A project or program may have multiple business change managers representing their respective lines of business. The business change manager defines and monitors key performance indicators to objectively measure the project's or program's success. The business change manager translates the technical aspects and benefits of a project or program into a format that is understandable to and executable by business line management and staff. Business change managers plan and manage business continuity during and immediately after the change takes place.
- **Project or program management office or organization (PMO) personnel:** Traditional project management methodologies, such as waterfall, typically centralize project governance through the PMO. The entity's size, complexity, and project types determine the number and qualifications of PMO personnel. Larger or more complex entities often have numerous PMO personnel to coordinate the projects and programs undertaken by an entity. Smaller or less complex entities often do not have designated PMOs or dedicated project personnel. The IT project's size and complexity determine the PMO's extent of engagement. Beyond keeping projects on track and identifying and removing obstacles, PMO activities

generally involve analyzing the project’s feasibility and risk; determining whether to develop, acquire, or outsource systems and components; ensuring quality of deliverables; and verifying that the project delivers value to the entity and affected business units.

- **Stakeholders:** Stakeholders should be involved early in the planning process to provide input before finalizing project requirements. In addition, regular communication between project managers and stakeholders helps to ensure that stakeholders agree with the project’s proposed direction. The list of potential stakeholders can be internal or external and may include the following individuals:¹⁶

Internal stakeholders	External stakeholders
Board of directors	Customers, consumers of critical services, or financial institution clients of a third party
Senior management	Third parties (e.g., service providers, suppliers, or partners)
Heads of business lines, especially critical service owners	User groups
Relevant internal business unit personnel (e.g., IT, human resources, compliance, and legal)	Shareholders

II.B.3 Development Roles

Development personnel typically encompass the technology professionals charged with designing, building, and maintaining solutions to solve a business problem or fulfill technology needs identified by business strategy. Development personnel may create solutions to support new products offered to customers, expand existing system capacity to support growth, or integrate systems after a merger. Larger or more complex entities may have separate personnel or departments to fulfill development roles, or varying development roles may have more granular responsibilities (e.g., user interface developers, software engineers, or mobile application developers). In smaller or less complex entities, roles may overlap, which may be acceptable if appropriate mitigating controls are in place. Third parties may help the entity with or serve in development roles.

Segregation of duties and dual controls or other compensating controls are important for development, acquisition, and maintenance activities because they help foster security and resilience. For example, segregation of development and implementation duties helps ensure that developers cannot directly alter the production environment. Inappropriate developer access may adversely affect the production environment’s confidentiality, integrity, availability, or resilience. Effective dual control allows management and other personnel to identify and address problems earlier since no single person or group can make changes or modifications without appropriate approval. Without dual control, seemingly small coding, building, and patching problems can quickly escalate in scale.

¹⁶ Refer to Cybersecurity and Infrastructure Security Agency (CISA), [CRR Supplemental Resource Guide, Vol. 3: Configuration and Change Management, Version 1.1](#). Also refer to CISA, [CRR Supplemental Resource Guide, Vol. 5: Incident Management, Version 1.1](#).

Typically, development deliverables are software applications or smaller modules of a larger application or system. Some larger or more complex entities, however, employ software engineering specialists to modify firmware, customize third-party-developed in-house applications, or adapt hardware products, such as automated teller machines (ATM), cash dispensers, and passbook or receipt printers to fit the entity's specific needs. Larger or more complex entities, especially those providing cloud, managed security, and payments services, often build proprietary hardware (e.g., servers or point-of-sale terminals) used in-house and by customers they service.

Staff roles that support development include the following:

- **Network architects:** Network architects generally design, select, and implement the appropriate system architecture to satisfy stakeholder requirements and achieve the desired results under given constraints. Network architects often have extensive knowledge of the entity's business plan to design a network to help the entity achieve its strategic objectives. They create plans and layouts for data communication networks and present those plans to management; explain risks; and justify recommended designs, changes, and consequences of inaction. They consider security when designing networks and systems. Once network architects define the appropriate architecture, they generally document and communicate it to the developers. Network architects upgrade hardware and software as needed to support solutions. After deployment, they may support those networks and troubleshoot any issues. When needed, network architects research new or emerging technologies to determine whether they are appropriate to implement for the entity. They evaluate network traffic to estimate growth and determine capacity management needs. Network architects may work with other IT personnel, such as network or system administrators and information systems managers, to ensure that networking needs are met. They work with third parties to manage upgrades and support the networks. Larger or more complex entities may define additional roles for enterprise architecture, including software and hardware architecture.
- **Developers:** Developers create software and the underlying systems and components to support an entity's business lines and strategic objectives, including security and resilience. They analyze users' needs and design and develop software to meet those needs, including how the systems or components will work together. Developers should have a clear understanding of user requirements and needs to ensure that deliverables meet user expectations. Developers document every aspect of a system or component as a reference for future maintenance and upgrades. They help ensure that a program continues to function normally through regular maintenance and, when necessary, recommend upgrades to keep pace with technology and security needs. They communicate with quality management personnel and testers to ensure that the system or component operates as envisioned. Developers may specialize in a particular language, platform, or business sector and may work individually in small or large teams.
- **Software engineers:** A software engineer is a type of developer who has a broad view of a project's system and software requirements and plans its scope and order of work. Software engineers may direct software developers, QA analysts, and testers.¹⁷
- **Hardware engineers:** Hardware engineers typically design new hardware. As part of the

¹⁷ Refer to the U.S. Bureau of Labor Statistics' [Occupational Outlook Handbook, "Software Developers, Quality Assurance Analysts, and Testers."](#)

design process, hardware engineers create schematics of equipment to be built and test the hardware. They analyze test results and modify the design as needed. Hardware engineers often work with developers to ensure that hardware components work together with the latest software. Additionally, hardware engineers oversee the manufacturing process for hardware. Many hardware engineers design devices used in manufactured products that incorporate processors and other computer components and that connect to the internet (e.g., point-of-sale terminals, card readers, and ATMs).

- **Information security analysts:** Information security analysts plan and carry out security measures to protect an entity's networks and systems. They work with developers to build security into systems and components and maintain the security aspects once developed. The role specializes in building and performing security assessments, identifying threats to systems, and ensuring that the software complies with the entity's security standards and policies. Information security analysts should have an enterprise-wide understanding of the entity's security architecture and interoperability of systems and components.
- **Systems analysts:** Systems analysts can also be referred to as systems architects. Systems analysts use their knowledge of the entity's systems, procedures, and technology needs to help IT personnel design systems that operate more efficiently and support the enterprise-wide business and strategic objectives. Systems analysts work with other IT personnel to help an entity's business leaders understand how systems and components support the entity's strategic and business line goals and objectives. Systems analysts devise ways to add functionality to systems by researching different technologies and analyzing costs and benefits of changing, upgrading, or implementing new IT systems to help managers decide which, if any, to install. Systems analysts validate the communication and interface between systems to ensure that they continue to function. They work with other IT personnel to evaluate system capacity needs. They work with business personnel to write instruction manuals and train the systems' end users. Additionally, systems analysts may work with other IT personnel to solve problems that arise after the initial system setup.

II.B.4 Acquisition Roles

Acquisition personnel typically procure systems or components. Larger or more complex entities may have separate individuals, teams, or departments responsible for acquisition. Acquisition personnel are often assisted by representatives from several departments, such as project management, IT, contracting, finance, information security, legal, and third-party risk management. Acquisition-related roles may be broken down further into the product or service type purchased (e.g., technology component). At smaller or less complex entities, the acquisition role often is one of multiple duties assigned to an individual (e.g., IT manager or president), which is acceptable if mitigating controls are in place. Additionally, third parties may perform the entity's acquisition activities (e.g., cloud access security broker). Segregation of duties, dual controls, and other compensating controls are important in acquisition activities to avoid conflicts of interest (e.g., choosing third parties based on relationships versus whether the third party provides the appropriate product, best service, or most advantageous price). Depending on whether the entity chooses to develop IT solutions or procure them from third parties, acquisition roles may vary.

General responsibilities include specifying what is required, requesting proposals, receiving bids from third parties, evaluating bids and bidders, initiating contracts, and managing contractual relationships. Responsibilities also include evaluating supply chain risks related to third parties (e.g., geopolitical risk for third parties outside the United States). These responsibilities may require specialized knowledge to evaluate pricing and other aspects (e.g., contract terms or support services) of the relationship. Responsibilities are carried out throughout the entire life cycle of the third-party relationship.¹⁸ For more information, refer to the “[Acquisition](#)” section of this booklet.

Roles that support acquisitions include the following:

- **Procurement manager:** A procurement manager can also be referred to as a third-party risk manager or business relationship manager. The procurement manager is responsible for the procurement strategy being consistent with the entity’s overall strategy and risk appetite. Procurement managers are responsible for developing the entity’s procurement policies, standards, and procedures to help ensure that procurement personnel avoid potential conflicts of interest or inappropriate third-party relationships. Procurement managers evaluate third parties based on the price, quality, functionality, and delivery speed of products and services. They verify that vendor processes align with the entity’s requirements (e.g., security and resilience) by interviewing vendors and visiting third-party facilities. They analyze proposals, financial reports, and other information to determine reasonable costs, negotiate contracts on the entity’s behalf, and arrange agreements with third parties (e.g., service-level agreements [SLA] or product delivery time frames). Procurement managers evaluate and monitor contracts to ensure that third-party management complies with the contract’s terms and conditions (including compliance with applicable laws and regulations) and determine the need for changes. When necessary, procurement managers meet with entity and third-party management to discuss defective or unacceptable products or services and determine corrective action. Procurement managers maintain and review records of items bought, costs, deliveries, product performance, and inventories. They may attend meetings, trade shows, and conferences to learn about new industry trends and make contacts with potential third-party partners. Procurement managers may work with other personnel, including those in program management, IT, information security, or business lines involved in the project.
- **Third-party risk manager:** This role can also be referred to as third-party relationship manager and may also be the same person as the procurement manager. This role involves performing due diligence on third parties before procuring systems, components, or contracting for services (e.g., development or information security activities). When appropriate, the third-party risk manager performs ongoing oversight over third parties throughout the relationship’s life cycle.

¹⁸ The term “business arrangement” may also be used and is meant to be interpreted broadly; it is synonymous with the term “third-party relationship.” A third-party relationship may exist despite a lack of a contract or remuneration. Third-party relationships can include outsourced services, use of independent consultants, referral arrangements, merchant payment processing services, services provided by affiliates and subsidiaries, and joint ventures.

II.B.5 Maintenance Roles

Appropriate personnel should perform maintenance throughout the life cycle of systems and components. Some responsibilities assigned as part of maintenance include asset management (including end-of-life [EOL] and end-of-support [EOS] management), patch management, vulnerability management, and performance and capacity management. Management should understand maintenance roles and related responsibilities. Maintenance personnel should have knowledge and understanding of all relevant systems and components they are expected to operate and maintain. Both maintenance personnel and management should analyze, document, and understand the costs of maintenance (e.g., budget, time, or personnel) versus the costs of not performing maintenance (e.g., system failures, data breaches, and customer dissatisfaction). Larger or more complex entities may have separate individuals, teams, or departments charged with maintenance. At smaller or less complex entities, maintenance roles may be part of other roles or duties that an individual may have, which is acceptable if mitigating controls are in place (e.g., segregation of duties and dual controls). Additionally, third parties may perform responsibilities related to maintenance for the entity, according to contractual agreements.

IT staff are generally responsible for maintaining an entity's systems and components to ensure that they continue to operate as expected. Maintenance generally includes performing updates and applying patches, monitoring the systems' or components' status, and monitoring the servers and infrastructure that support the entity's systems and components. Maintenance roles may have more granular responsibilities (e.g., network support) depending on the complexity of the entity's IT environment. Maintenance roles should be independent from development roles to prevent developers from accessing production environments. For more information, refer to the "[Maintenance](#)" section of this booklet.

II.B.6 Other Common Development, Acquisition, and Maintenance Roles

Depending on the entity's size and complexity, the following roles are common to development, acquisition, and maintenance activities:

- **Configuration or change control board (CCB):** The CCB is "a group of qualified people with responsibility for the process of regulating and approving changes to hardware, firmware, software, and documentation throughout the development and operational life cycle of an information system."¹⁹ The CCB typically is part of an entity's change management process, and it reviews and prioritizes change requests related to a project or production environment.
- **Testers and quality assurance analysts:** During development, acquisition, and maintenance, testers and quality assurance analysts create test plans, scenarios, and procedures for new or changed systems and components to confirm that they function as intended. Testers are responsible for testing systems, components, and controls regardless of whether they are developed internally or procured from a third party. Testers design and conduct tests to check systems and components for problems. They identify, document, and

¹⁹ Refer to [NIST Glossary](#).

report risks from test results and recommend steps to minimize or resolve risks or defects. They assess the usability and functionality of systems and components to identify issues, including difficulties a user might have. They can use manual or automated processes, with additional testing as necessary, and evaluate results. Testers document the results of testing and report defects or problems to developers, project teams, and other stakeholders. Once the system or component is released to production, testers run additional tests to look for errors and usability problems. They perform tests after any upgrades, maintenance, or implementation of patches and fixes on a system or component to validate the changes made. Depending on the types of tests performed (e.g., unit, security, regression, and integration), other testers may be involved at various SDLC phases, based on the testers' roles and knowledge of the system or component and its use. For more information, see the "[Testing](#)" section in this booklet.

II.B.7 Supply Chain Roles

Typically, supply chain personnel are responsible for implementing and managing systems and components throughout the entity's supply chain. Larger or more complex entities may have separate individuals, teams, or departments charged with supply chain roles and responsibilities. These personnel may include representatives from several key departments, such as development, procurement (including logistics and product delivery), maintenance, project management, IT, contracting, finance, information security, and third-party risk management.

Common internal roles may be the chief risk officer, CIO, CISO, program executive, program manager, system engineers or system security engineers, and other personnel. Common external supply chain roles may be suppliers, developers, system integrators, third-party system service providers, and other external personnel responsible for supply chain activities as noted in agreements (e.g., contracts) between the entity, third parties, and their subcontractors.²⁰

II.B.8 Other Support Functions

Several lines of business and other support functions should be involved in overseeing or validating development, acquisition, and maintenance activities early in the process. One of those functions may be end-user and customer support, often referred to as the IT help desk. The end-user and customer support role works with development, acquisition, and maintenance personnel to respond to user or customer concerns. This role may also assist with resolving problems that cannot be corrected quickly. Moreover, this role provides feedback to development, acquisition, and maintenance personnel about the functionality of products and services. This role records the details of customer or user interactions and the resolution of problems. End-user and customer support staff should understand the escalation process and the personnel who can address more complex problems.

²⁰ For more information on common external supply chain roles, refer to NIST Special Publication (SP) 800-161r1, [Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#).